Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 1.6 / COMPANION WORKBOOK

Finish the PKI services

pki.sbd.test publication & template administration

Give the PKI its services: the pki.sbd.test publication site on SBD-PKI-MGMT01, trust data at the exact embedded URLs, template administration on its own seat, and the lab's first working templates proven by pilot autoenrollment.

MATERIALS EDITION 1.0 / COURSE 1.6

Updated 7 October 2026 · sbd-pki-services

NAME _____ / DATE _____

© 2026 Secure By Design Team LLC.

Table of contents

Read each lesson alongside the interactive guide and the video. Use the record tables to write down what you actually observe — the workbook is your evidence, not the guide.

Before you start

01 Build the pki.sbd.test publication site

02 Publish the trust data at its advertised URLs

03 Separate template administration

04 Publish the first working templates

05 Validate enrollment and delta scan

Course review and sign-off

> **HOW TO USE IT** Each lesson page has the same shape: what you will learn, the build steps, the commands that verify them, and a record table. Fill the table from your own environment — never from the sample values.

© 2026 Secure By Design Team LLC.

Before you start

This course finishes the PKI chapter: the pki.sbd.test publication site goes live on SBD-PKI-MGMT01, and certificate template administration moves to that host, off the issuing CA. Publication stays plain HTTP by design — clients must be able to fetch revocation data before they can validate any certificate.

Prerequisites

- ☐ Complete courses 1.4 and 1.5: a working two-tier PKI and the routed, default-deny network with pki.sbd.test reachable over HTTP per the register.
- ☐ Build SBD-PKI-MGMT01 as a hardened Windows Server 2025 member server at 10.0.30.30 in the Servers OU.
- ☐ Have the issuing CA's AIA and CDP URL plan from course 1.4 at hand — the filenames published here must match those embedded URLs exactly.

What this course builds

- Publish certificates and CRLs at the exact URLs issued certificates carry.
- Move template administration to a delegated seat with a written change process.
- Prove pilot autoenrollment and live revocation retrieval across the routed network.

Systems in scope

RECORD	YOUR OBSERVATION
SBD-PKI-MGMT01 — name, address, OS build	
SBD-SUBCA01 — name, address, OS build	

LESSON 01 / ABOUT 30 MIN

Build the pki.sbd.test publication site

> **WHY THIS MATTERS** Every certificate the issuing CA has signed carries the pki.sbd.test URLs inside it. This lesson gives those URLs a real home: a small web site on SBD-PKI-MGMT01 serving certificates and revocation lists to the whole network.

In this lesson you will

- Stand up the HTTP publication site on SBD-PKI-MGMT01.
- Confirm the DNS alias from course 1.2 points at the publication host.
- Explain why CDP and AIA publication uses HTTP, not HTTPS.

Follow the build

1. On SBD-PKI-MGMT01, install the Web Server role and create a site (or virtual directory) whose folder will hold the published certificates and revocation lists. Serve .cer, .crt, and .crl files; nothing else belongs in this directory.
2. Confirm the pki.sbd.test alias from course 1.2 resolves to 10.0.30.30 from a client in another VLAN, and that the register's HTTP row from course 1.5 permits the path.
3. Leave the site on plain HTTP. Revocation checking has to work before any certificate can be trusted — putting the CRL behind HTTPS creates a loop where validating the site needs the very file it serves.
4. Restrict who can write to the publication folder: the CA's publishing process and the PKI administrators, nobody else. Clients read; they never write.

Check your result

```
Resolve-DnsName pki.sbd.test
Test-NetConnection pki.sbd.test -Port 80
Get-Website | Select-Object Name, State, PhysicalPath
```

> **WHAT SUCCESS LOOKS LIKE** pki.sbd.test resolves to the publication host from outside VLAN 30, the site answers on port 80, and the publication folder's permissions separate writers from readers.

Your record

Evidence to keep: Record the site configuration, folder permissions, the DNS resolution output from a cross-VLAN client, and the register row that permits the path.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

Why does the publication site stay on plain HTTP?

> **REMEMBER** pki.sbd.test now answers from SBD-PKI-MGMT01 over HTTP. Only public artifacts live in the folder; only PKI processes write to it. The transport is HTTP on purpose — revocation precedes trust.

Microsoft · PKI design considerations

Microsoft · Certutil reference

LESSON 02 / ABOUT 25 MIN

Publish the trust data at its advertised URLs

> **WHY THIS MATTERS** A publication site is only correct when the filenames it serves match the URLs the certificates already carry. Copy the current certificates and CRLs into place, wire the issuing CA to keep them fresh, and prove retrieval from a client that has never cached anything.

In this lesson you will

- Publish the root and issuing certificates and current CRLs at the exact embedded URLs.
- Configure the issuing CA to refresh its published files automatically.
- Prove live retrieval and chain building from a cross-VLAN client.

Follow the build

1. Compare the issuing CA's configured AIA and CDP URLs against the publication folder's layout. Every embedded URL must map to a real file path on the site — the filenames are not yours to improve.
2. Copy the current root certificate, root CRL, issuing certificate, and issuing CRL into the folder. The root's files still arrive by approved media; the issuing CA's can be written directly by its publishing process.
3. Configure the issuing CA's CRL publication to write into the site's folder on its schedule, so each new CRL replaces the old file at the same name before it expires.
4. From a clean client in another VLAN, fetch each URL and run the full verification: the chain must build and revocation data must come from the live site, not a cache.

Check your result

```
certutil -verify -urlfetch C:\Evidence\pki\test.cer
certutil -URL http://pki.sbd.test/RootCA.crl
Get-ChildItem C:\inetpub\pkiroot | Select-Object Name, LastWriteTime
```

> **WHAT SUCCESS LOOKS LIKE** Every AIA and CDP URL embedded in issued certificates returns the current file, urlfetch verification passes from a cross-VLAN client, and the CRL refresh lands at the same filename automatically.

Your record

Evidence to keep: Keep the URL-to-file mapping table, the folder listing with timestamps, and the urlfetch output from the clean client.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

Why can't the published filenames be renamed to something tidier?

> **REMEMBER** Published filenames mirror the embedded URLs exactly. The issuing CA refreshes its files on schedule; the root's arrive by media. A clean cross-VLAN client proves the chain and live revocation.

Microsoft · PKI design considerations

Microsoft · Certutil reference

LESSON 03 / ABOUT 25 MIN

Separate template administration

WHY THIS MATTERS Certificate templates are directory objects, and whoever edits them decides what the PKI will sign. Give that power its own seat — SBD-PKI-MGMT01 — with named administrators, instead of leaving it wherever a CA console happens to be open.

In this lesson you will

- Establish SBD-PKI-MGMT01 as the only administration seat for templates.
- Delegate template permissions to a named PKI administrators group.
- Record the template change process before any template changes.

Follow the build

1. Install the certificate management tools on SBD-PKI-MGMT01 and confirm the Certificate Templates console can read the directory's template store from there.
2. Create a PKI administrators group in the directory, place it under the Admin OU from course 1.3, and delegate the template permissions to that group — membership is the record of who may change what the CA signs.
3. Remove day-to-day template editing from everywhere else: the issuing CA's console stays for CA operations, not template design, and no Tier-0 account edits templates as routine work.
4. Write the change process: a template change names its requester, its reviewer, the versioning action (edit, duplicate, or supersede), and lands in the evidence record like any other configuration change.

Check your result

```
Get-ADGroup 'SBD PKI Admins' -Properties Members | Select-Object Name, Members
certutil -template | Select-String 'TemplatePropCommonName' | Select-Object -First 10
```

WHAT SUCCESS LOOKS LIKE The templates console works from SBD-PKI-MGMT01, the PKI administrators group holds the delegated permissions, and the written change process names requester, reviewer, and versioning action.

Your record

Evidence to keep: Keep the delegation record, the group membership listing, and the signed-off template change process.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

Why do certificate templates deserve their own administration seat?

> **REMEMBER** SBD-PKI-MGMT01 is the template administration seat. A named group under the Admin OU holds the delegated power. Template changes have a written process before they have edits.

Microsoft · PKI design considerations

Microsoft · Manage certificate templates

LESSON 04 / ABOUT 25 MIN

Publish the first working templates

> **WHY THIS MATTERS** The default template set is a menu, not a deployment. Duplicate the two templates this network actually needs — computer authentication and server authentication — set their cryptography deliberately, and publish only those.

In this lesson you will

- Duplicate and configure the computer and web server templates against the approved plan.
- Set key sizes and validity that satisfy the Windows Server 2025 minimums.
- Publish only the needed templates, scoped to a pilot group first.

Follow the build

1. From the administration seat, duplicate the Computer template as SBD Computer Authentication. Set the approved key provider, a key size of at least 2,048 bits, subject built from directory information, and autoenrollment permission for a pilot computer group only.
2. Duplicate the Web Server template as SBD Server Authentication for the services wave ahead: enrollment permission for the server administrators, no autoenrollment, and exportable keys only if the recovery plan explicitly says so.
3. Record each template's version, settings, and justification through the lesson-3 change process before publishing.
4. Publish exactly these two templates on the issuing CA and remove any default template the plan does not call for — an unpublished template cannot be mis-enrolled.

Check your result

```
certutil -CATemplates -config 'SBD-SUBCA01\SBD Issuing CA'
certutil -template 'SBDComputerAuthentication' | Select-String 'msPKI-Certificate-Name-Flag','msPKI-Minimal-Key-Size'
```

> **WHAT SUCCESS LOOKS LIKE** The CA publishes exactly the two planned templates, each shows the approved key size and permissions, and both carry a completed change record.

Your record

Evidence to keep: Keep each template's configuration export, its change record, and the CA's published-template listing.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

Why duplicate the built-in templates instead of editing them?

REMEMBER Two named templates exist, configured on purpose, nothing else published. Key sizes meet the 2025 floor; permissions are pilot-scoped. Every template carries its change record.

Microsoft · Manage certificate templates

Microsoft · Configure certificate autoenrollment

Microsoft · What's new in Windows Server 2025

LESSON 05 / ABOUT 15 MIN

Validate enrollment and delta scan

> **WHY THIS MATTERS** Close the loop the way course 1.4 did, but now across the routed network: a pilot machine enrolls automatically, validates against the live publication site, and the change-triggered scans record what this course did.

In this lesson you will

- Prove pilot autoenrollment through the published template.
- Verify chain and revocation against pki.sbd.test from the enrolled client.
- Run the course's delta scans and file the evidence.

Follow the build

1. Enable the autoenrollment policy for the pilot computer group, refresh policy on a pilot machine, and confirm it receives an SBD Computer Authentication certificate without a human touching the request.
2. On that machine, run the full verification: the chain must reach the approved root and every revocation URL must answer from pki.sbd.test across the boundary.
3. Rescan SBD-SUBCA01 and take SBD-PKI-MGMT01's first baseline with the same benchmark and tool versions as always; the publication site and template changes are the expected deltas.
4. File the course evidence: enrollment output, urlfetch results, template records, and the scan set — wave 2 is complete and the PKI chapter is finished.

Check your result

```
gpupdate /force
certutil -pulse
Get-ChildItem Cert:\LocalMachine\My | Select-Object Subject, NotAfter, Thumbprint
certutil -verify -urlfetch C:\Evidence\pki\pilot.cer
```

> **WHAT SUCCESS LOOKS LIKE** The pilot enrolls hands-free, verification passes with live retrieval from pki.sbd.test, and both VLAN 30 hosts have current, attributed scan results.

Your record

Evidence to keep: Keep the pilot's certificate details, the urlfetch output, and the delta-scan comparison for SUBCA01 plus the PKI-MGMT01 baseline.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

What does a hands-free pilot enrollment prove?

> **REMEMBER** Pilot autoenrollment works end to end across the routed network. Live revocation retrieval from pki.sbd.test is proven, not assumed. Delta scans and evidence close the PKI chapter.

Microsoft · Configure certificate autoenrollment

Microsoft · Certutil reference

Course review and sign-off

Before moving on, confirm each lesson left evidence behind — and that what remains open is written down, not remembered.

Lesson completion

LESSON	EVIDENCE FILED	DATE
01 Build the pki.sbd.test publication site	☐ yes	
02 Publish the trust data at its advertised URLs	☐ yes	
03 Separate template administration	☐ yes	
04 Publish the first working templates	☐ yes	
05 Validate enrollment and delta scan	☐ yes	

Open items carried forward

Next in the learning path

That completes course 1.6. Course 1.7 brings DHCP and the tiered administration plane online before any fleet exists.

> **KEEP IT HONEST** Lesson completion records learning activity; it is not a system authorization decision. Your observations, not the sample values, establish what happened in your environment.

© 2026 Secure By Design Team LLC.